

ISMS ALS VERÄNDERUNGSPROJEKT

Fallstudie 1: Maschinenbau Augsburg GmbH

Präsentiert von Vaisakh Narayanan Nair M.Eng.

Zielgruppe: Geschäftsführer, Betriebsrat

Augsburg, 12.06.2026

ÜBER MICH

Aus Datenschutzgründen leer gelassen

Kapitel 1

CYBERCRIME NIMMT WEITER ZU

Motivation

	Pilz GmbH & Co. KG (10.2021) Analoge Interimsbetrieb, Datenverlust
	Schumag AG, Aachen (09.2024) Antrag auf Sanierung in Eigenverwaltung
	Kreisel GmbH & Co. KG, Saxony (2024) Insolvenz
	Brockhaus Fertigungstechnik GmbH, NRW (01.2026) Ransomware (Akira) → Data exfiltration (IP, Kundendata)
	Wertachkliniken, Bobingen & Schwabmünchen (09.2024) massiven operativen Einschränkungen, Abfluss sensibler Patientendaten
	Unnamed manufacturing company, Bayerisch-Schwaben (06.2025) Ransomware (server encryption + backup deletion)
	Kalchschmid GmbH & Co. KG, Günzburg (08.2025) Pear-Gruppe (double extortion)
und mehr.	

€ 202Mrd
Gesamtschaden durch Cyberkriminalität in Deutschland 2025

Quelle: Bitkom e.V., 2025; +20% gegenüber Vorjahr

21 Tage
Produktionsstillstand nach
Ransomware

Quelle: IBM Security 2025

27,7 %
Aller globalen Angriffe treffen
die Fertigungsindustrie

Quelle: IBM X-Force 2025

80%
der angezeigten Cyberangriffe
in Deutschland betrafen KMUs

Quelle: BSI-Report-2025*

≥ 20 %
Bayerischer Betriebe Opfer
eines erheblichen
Cybervorfalls

Quelle: IHK München, 2026

Der Schutz der Angriffsflächen ist 2026 der entscheidende Hebel, um die Cybersicherheit zu verbessern*



IST-ZUSTAND: Augsburg Maschinenbau GmbH

Die 3 Dimensionen der Verwundbarkeit



Kulturelle Dissonanz

Sicherheit wird nicht als Qualitätsmerkmal, sondern als Produktivitätshemmnis verstanden.

- Führungskräfte priorisieren Output über Sicherheit.
- Starke Skepsis gegenüber IT-Kontrolle auf dem Shopfloor.
- Sicherheitsregeln werden in der Produktion aktiv umgangen.



Strukturelle Defizite

Es fehlt das Fundament für ein systematisches Management der Informationssicherheit.

- 3-köpfige IT-Abteilung im operativen Dauerstress.
- Keine systematische Risikoanalyse vorhanden.
- Fehlende Governance: Keine klaren Rollen, kein bestellter ISB.



Technische Schwächen

Kritische Einfallstore bleiben offen und gefährden die gesamte Wertschöpfungskette.

- Lebensgefährliche Vermischung von IT- und OT-Netzen (Produktion).
- Unsichere und unregulierte Remote-Zugriffe für Dienstleister.
- Backups werden nicht regelmäßig auf Wiederherstellbarkeit getestet.



AUGSBURG
MASCHINENBAU GmbH

Financial Damage

Ransomware Lösegelder,
Bußgelder (z.B. NIS2,
GDPR), IP-Verlust

[1]

Operational Damage

21 Tage Produktionsstillstand

[1]

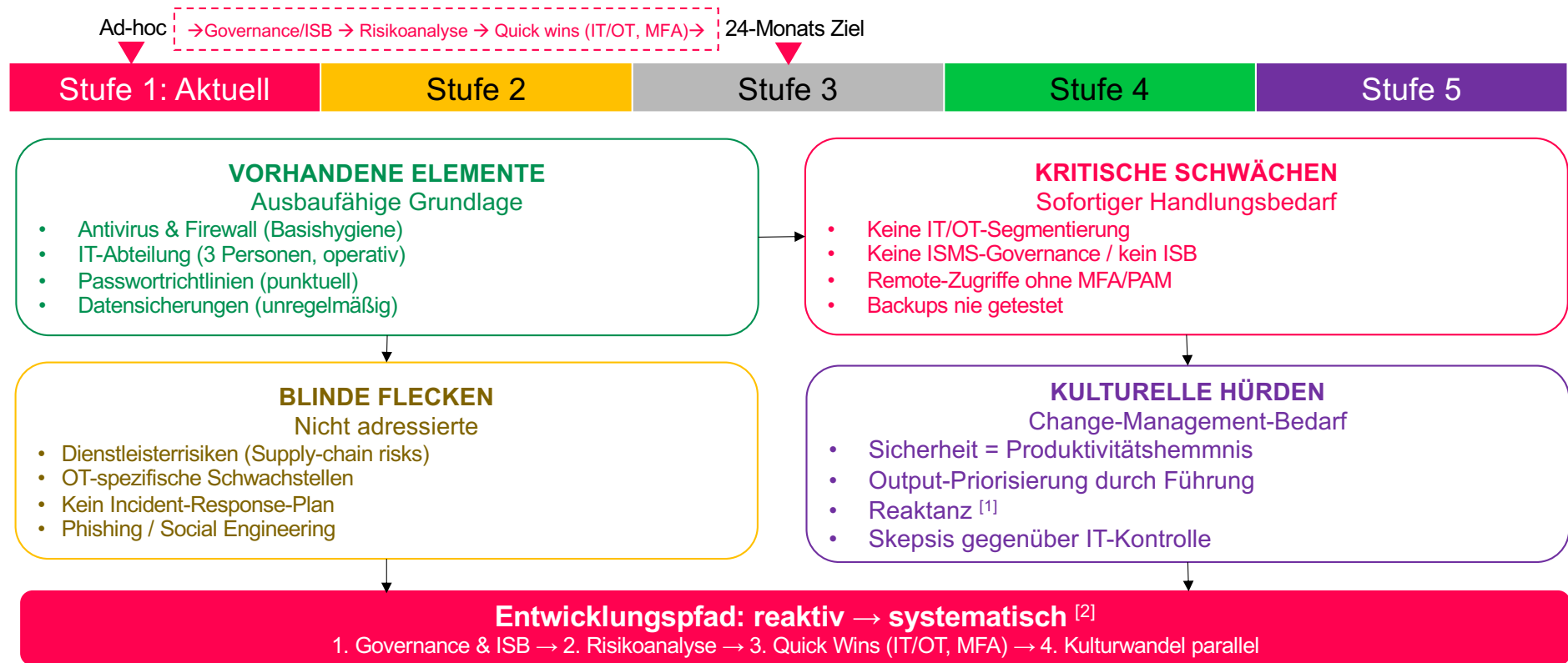
Reputational Damage

Markenerosion,
Vertrauensverlust bei Kunden

[1]

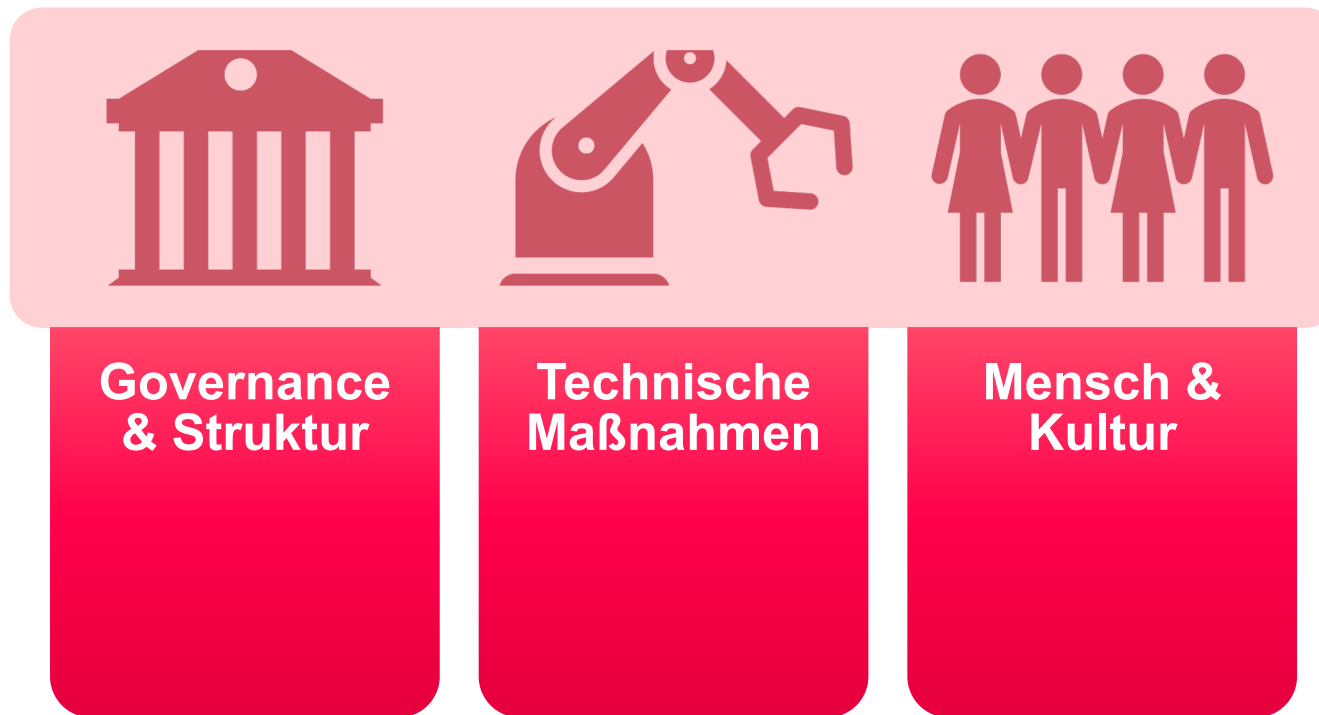
SICHERHEITSGRADANALYSE

Ausgangssituation: Stufe 1 (Ad-hoc) → Stufe 3 (Defined/Managed) ^[2]



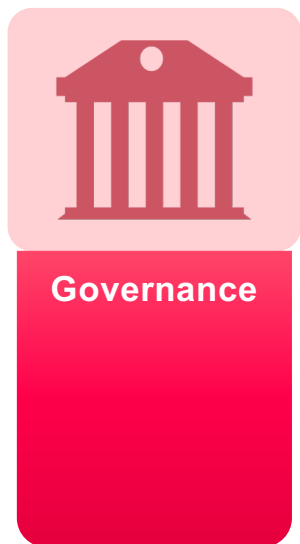
KONKRETE MAßNAHMEN: DREI HANDLUNGSEBENEN

Governance, Technik und Mensch/Kultur: parallel adressiert



KONKRETE MAßNAHMEN: DREI HANDLUNGSEBENEN

Governance & Struktur



1

ISB benennen

Monat 1

Informationssicherheitsbeauftragter
Mandat von Geschäftsführung: NIS2 Art. 20, BSIG §30

2

ISMS-Leitlinie unterzeichnen

Monat 2

Geschäftsführung-Unterschrift gibt Signalwirkung
• Tone from the Top (ISO 27001:2022 Kap. 5)

3

Risikoanalyse (ISO 27005)

Monat 2–3

Strukturierter Prozess mit ISB + IT + Produktion
Basis für alle weiteren Maßnahmen

Rolle der Geschäftsführung

GF unterzeichnet ISMS-Leitlinie öffentlich Signalwirkung

Sicherheit als Agenda-Punkt
im monatlichen GF-Meeting Institutionalisierung

Teilnahme an Tabletop-Übung
(mind. 1× pro Jahr) Vorbildfunktion

+30 % Compliance durch sichtbares
Führungsengagement von Solms & van
Niekerk 2013

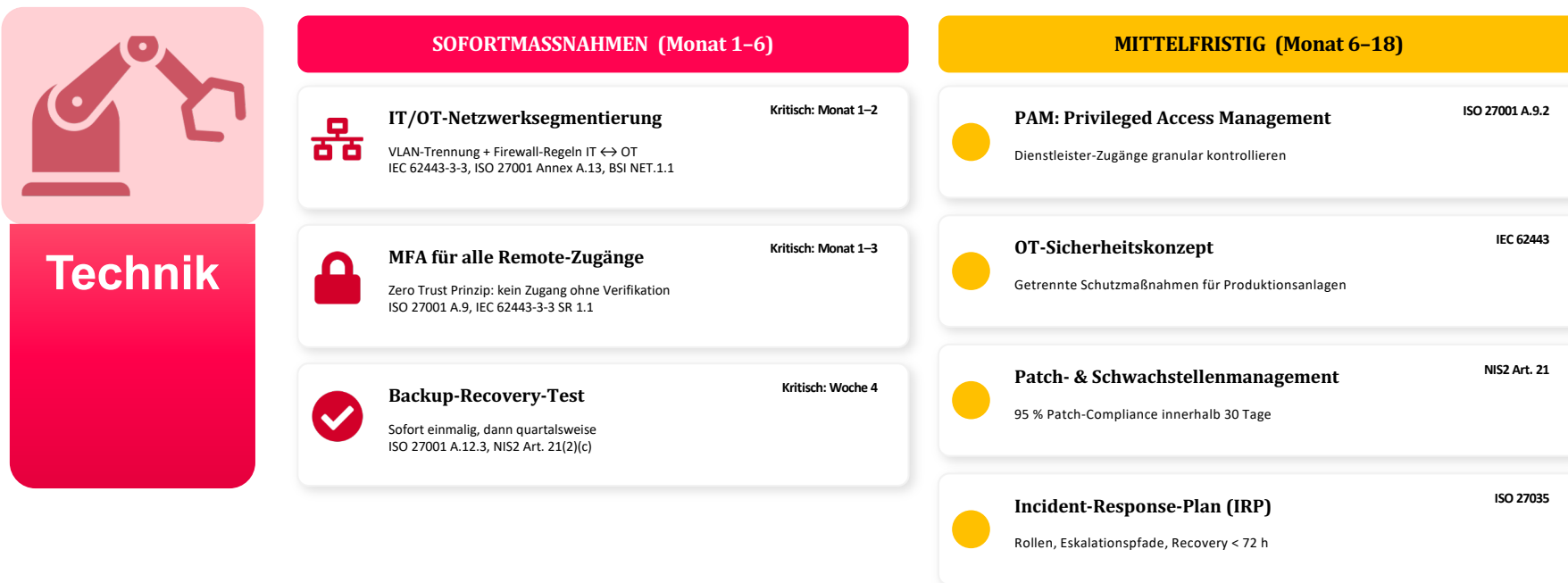
Spannungsfeld Produktion & Sicherheit: Security by Design (BSI ICS-Leitfaden 2023)

MFA via RFID-Badge statt Passwort, automatische Netzsegmentierung ohne manuelle Eingriffe

Kapitel 3

KONKRETE MAßNAHMEN: DREI HANDLUNGSEBENEN

Technik



Kapitel 3

KONKRETE MAßNAHMEN: DREI HANDLUNGSEBENEN

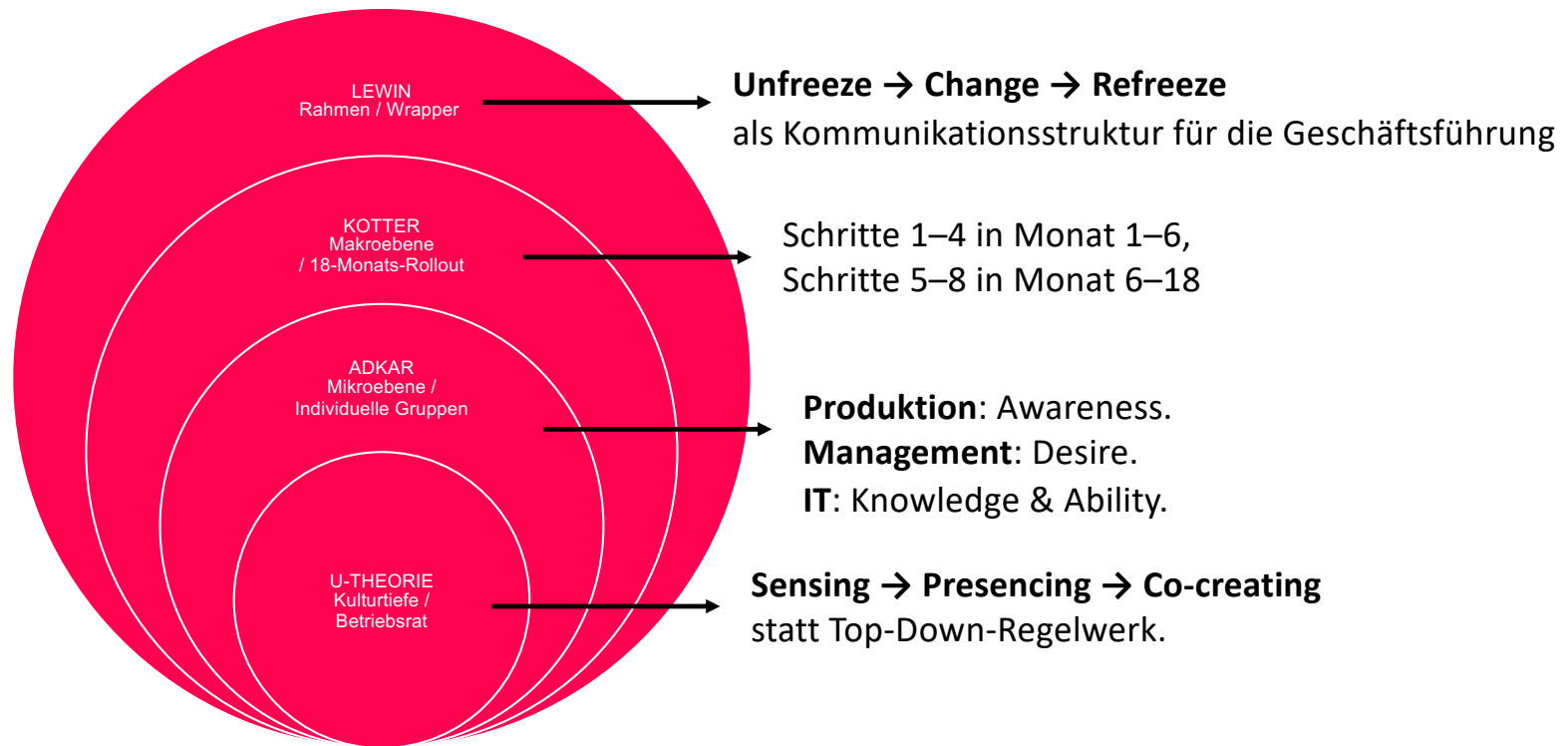
Kultur/Menschen

*Partizipative Regelentwicklung statt Top-Down-Dekret
Ziel: Sicherheit als Qualitätsmerkmal*



VIER MODELLE, EIN ANSATZ: WANDEL AUF ALLEN EBENEN GESTALTEN

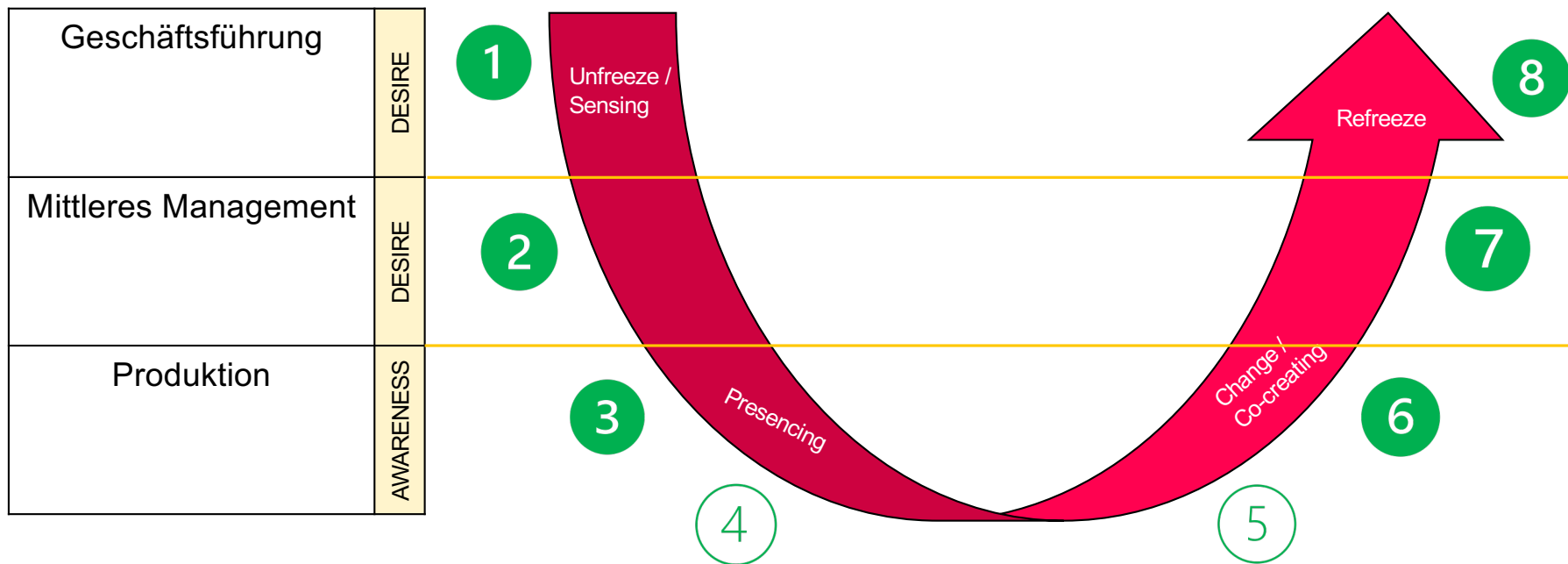
Wie gehen Sie mit dem Spannungsfeld zwischen Produktion, Kontrolle und Sicherheit um?



VIER MODELLE, EIN ANSATZ: WANDEL AUF ALLEN EBENEN GESTALTEN

Wie gehen Sie mit dem Spannungsfeld zwischen Produktion, Kontrolle und Sicherheit um?

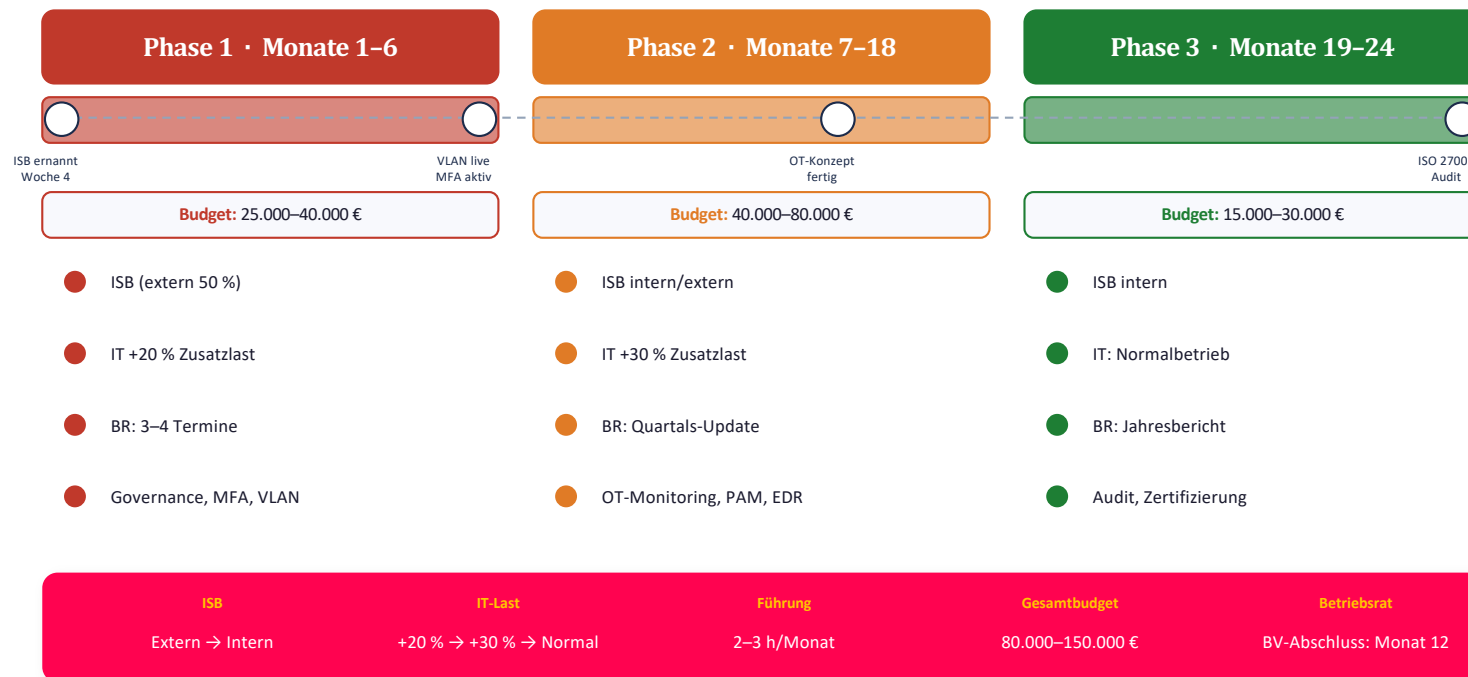
- Kotter
- U-Theory
- Lewin
- ADKAR



Kapitel 4

24-MONATS ROADMAP UND RESSOURCENBEDARF

Realistisch geplant



KOMMUNIKATIONSPLAN

Wer kommuniziert Was, Wann, auf Welchem Kanal?

Zielgruppe	Kernbotschaft	Medium / Format	Frequenz	Verantwortlich
Geschäftsführung	ROSI, Haftungsrisiko, NIS2 ISO 27001 Kap. 5 Leadership	GF-Meeting, 1-Pager	Monatlich	ISB
Führungskräfte (Schichtleiter, Bereichsl.)	Security by Design = keine Produktivitätshemmnis	Workshop, Champion-Briefing	Monat 1, dann Qrtl.	ISB + GF
Mitarbeitende / Produktion	Melden schützt – Bestrafungsfreiheit	Schichtmeeting, Awareness-E-Learning	Quartalweise	Champion
Betriebsrat	BV IT-Monitoring (BDSG §26) Mitgestaltungsrecht wahrnehmen	BR-Sitzung, BV-Entwurf	3–4× Phase 1, Qrtl. Update	ISB + GF

Messbare Akzeptanzmetrik: Ziel $\geq 90\%$ Schulungsabschlussquote | BR-Mitgestaltung senkt Blockaderisiko erheblich [Kotter 1996]

Kapitel 5

KPIs & ERWARTETE WIRKUNG

Realistisch geplant

KPI-Dashboard (ISO 27004:2016 · NIST SP 800-55)

MTTD	< 24 h	Mean Time to Detect
MTTR	< 4 h	Mean Time to Respond (krit. Systeme)
Patch-Compliance	≥ 95 %	innerhalb 30 Tage
Phishing-Klickrate	< 5 %	Branchenschnitt KMU heute: ~25 %
Backup-Recovery	100 %	Quartalweise getestet
Krit. Open Findings	= 0	aus Risikoanalyse
Schulungsquote	≥ 90 %	pro Jahr, alle Mitarbeitenden

Mittelfristig (12–24 Monate)

- ↓ Kritischer Schwachstellen um ≥ 80 %
- Recovery-Zeit: ? → < 72 h
- Phishing-Rate: 25 % → < 5 %
- NIS2-Compliance erreicht
- 0 ungeplante Remote-Zugänge

Langfristig (24–48 Monate)

- ISO 27001-Zertifizierung anstrebbbar
- Cyber-Versicherungsprämien sinkend
- GF-Haftungsrisiko sinkt (§43 GmbHG)
- Nachweis für Kunden & Lieferanten

ROSI – Return on Security Investment

Ransomware-Schaden: 21 Tage × Tageserlös vs. ISMS-Invest: 80–130k €

Gordon-Loeb-Modell: Optimaler Sicherheitsinvest ≈ 37 % des erwarteten Schadens